

## GUÍA METODOLÓGICA DETALLADA

### Diseño, Validación, Muestreo y Análisis de la Encuesta CAPEC-ESP

#### Kit de Encuesta CAPEC-ESP • Documento B • Versión 1.0 • Abril 2026

*«Una encuesta sin metodología es un sondeo de opinión disfrazado de ciencia. La diferencia no es cosmética: es la diferencia entre publicar en una revista de alto impacto y publicar en el boletín interno de la comunidad de vecinos.»*

## 1. FUNDAMENTO EPISTEMOLÓGICO

### 1.1 Paradigma de investigación

La encuesta se inscribe en el paradigma del **positivismo crítico**: asume que la adopción de marcos de seguridad en las organizaciones es objetivamente medible, pero reconoce que toda medición está condicionada por la perspectiva y el contexto del observador. Para mitigar el sesgo inherente, el instrumento combina:

- Preguntas de autoevaluación de madurez (percepción subjetiva del respondente)
- Preguntas de verificación conductual (¿qué hace la organización vs. qué valora?)
- Controles de consistencia interna cruzados entre secciones

### 1.2 Marco GQM (Goal-Question-Metric)

El instrumento aplica la metodología **GQM** de Basili, Caldiera & Rombach (1994), adaptada a la medición de madurez de ciberseguridad:

#### **Goal (Objetivo de medición):**

Analizar el estado de adopción del marco CAPEC en organizaciones españolas **con el propósito de** establecer un Índice de Madurez de referencia nacional **desde la perspectiva de** los responsables de ciberseguridad **en el contexto de** el ecosistema regulatorio NIS2/ENS/DORA y las amenazas emergentes de 2025.

#### **Questions (Preguntas de investigación):**

- Q1: ¿Cuál es el nivel de conocimiento y adopción de CAPEC por sector, tamaño y marco regulatorio?
- Q2: ¿Qué indicadores y métricas CAPEC están implementados y cuál es su cobertura por dominio?
- Q3: ¿Existe correlación entre el nivel de madurez CAPEC y el cumplimiento con NIS2/ENS?
- Q4: ¿Cuál es la preparación organizacional ante amenazas emergentes (IA adversarial, supply chain, quantum)?
- Q5: ¿Qué obstáculos y palancas determinan la adopción de CAPEC?

#### **Metrics (Métricas derivadas):**

- M1: **IGM-CAPEC** — Índice Global de Madurez CAPEC (métrica compuesta principal)

- M2: **IGC** — Índice de Gestión del Conocimiento
- M3: **ICM** — Índice de Cobertura de Métricas
- M4: **IAR** — Índice de Alineación Regulatoria
- M5: **IRD** — Índice de Resiliencia Digital
- M6: **IBE** — Índice de Brecha Emergente

## 2. DISEÑO DEL INSTRUMENTO

### 2.1 Tipo de instrumento

**Cuestionario estructurado auto-administrado de tipo mixto:**

| Tipo de ítem                              | Proporción | Uso                             |
|-------------------------------------------|------------|---------------------------------|
| Opción única (Likert ordinal de 5 puntos) | 30%        | Madurez, frecuencia, nivel      |
| Opción múltiple (check list)              | 40%        | Prácticas, herramientas, marcos |
| Tabla de autoevaluación matricial         | 20%        | Evaluación por dominio o patrón |
| Pregunta abierta                          | 10%        | Perspectivas cualitativas       |

**Total de ítems:** 50 preguntas en 11 secciones (incluyendo Sección 0 de identificación)

### 2.2 Estructura y contenido por sección

| Sección                       | Código      | Preguntas | Índice que alimenta        |
|-------------------------------|-------------|-----------|----------------------------|
| Identificación organizativa   | P0.1–P0.5   | 5         | Variables de clasificación |
| Conocimiento y adopción CAPEC | P1.1–P1.7   | 7         | IGC                        |
| Modelado de amenazas          | P2.1–P2.4   | 4         | IGC + ICM                  |
| Indicadores y métricas        | P3.1–P3.6   | 6         | ICM                        |
| Amenazas emergentes           | P4.1–P4.7   | 7         | IBE                        |
| Cumplimiento regulatorio      | P5.1–P5.4   | 4         | IAR                        |
| Resiliencia digital           | P6.1–P6.4   | 4         | IRD                        |
| Gestión de riesgos            | P7.1–P7.3   | 3         | IGC + ICM                  |
| Personas y cultura            | P8.1–P8.3   | 3         | IGC                        |
| Zero Trust                    | P9.1–P9.2   | 2         | IBE + IRD                  |
| Perspectiva estratégica       | P10.1–P10.5 | 5         | Cualitativo + estratégico  |

### 2.3 Escala de codificación de respuestas

Las respuestas se codifican de 1 a 5 según la siguiente escala de madurez:

| Valor | Etiqueta                              | Criterio operacional                                  |
|-------|---------------------------------------|-------------------------------------------------------|
| 1     | Inexistente / No implementado         | Control o práctica completamente ausente              |
| 2     | Inicial / En desarrollo               | Reconocido; en proceso de planificación o inicio      |
| 3     | Definido / Parcialmente implementado  | Existe como proceso, pero con lagunas o sin medición  |
| 4     | Gestionado / Ampliamente implementado | Proceso pleno con medición regular                    |
| 5     | Optimizado / En mejora continua       | Integrado, medido, revisado y mejorado periódicamente |

### 3. VALIDEZ Y FIABILIDAD

#### 3.1 Validez de contenido (CVI de Lawshe)

El instrumento fue sometido a revisión por un panel de **12 expertos**:

- 3 CISOs con más de 10 años de experiencia
- 2 investigadores académicos en ciberseguridad
- 2 especialistas en frameworks de amenazas (CAPEC, ATT&CK)
- 2 expertos en marcos normativos (ENS, NIS2, DORA)
- 1 metodólogo en ciencias sociales aplicadas
- 2 profesionales de GRC

#### Cálculo del Content Validity Ratio (CVR) de Lawshe (1975):

Para  $n = 12$  expertos, el umbral de aceptación es  $CVR > 0,56$  ( $p < 0,05$ ).

$$CVR = (n_e - N/2) / (N/2)$$

Donde  $n_e$  = nº de expertos que valoraron el ítem como "Esencial" y  $N$  = total de expertos.

El **Content Validity Index (CVI)** global del instrumento:

$$CVI = \text{Media aritmética}(CVR_i) \text{ para todos los ítems}$$

**Criterio de aceptación:** Todos los ítems deben superar  $CVR > 0,56$ . Los ítems que no lo superen serán reformulados o eliminados.

#### 3.2 Validez de constructo (AFC — Análisis Factorial Confirmatorio)

Con los datos del estudio piloto ( $n \geq 50$ ), se verificará la estructura de **5 factores latentes**:

- **F1: IGC** — ítems P1.1, P1.3, P1.4, P1.5
- **F2: ICM** — ítems P3.1, P3.3, P3.4, P3.5
- **F3: IAR** — ítems P0.4, P5.1, P5.2, P5.3, P5.4
- **F4: IRD** — ítems P6.1, P6.2, P6.3, P6.4
- **F5: IBE** — ítems P4.2, P4.4, P4.6, P4.7, P9.2

### Métricas de ajuste AFC (umbrales de aceptación):

| Métrica                                         | Umbral de aceptación |
|-------------------------------------------------|----------------------|
| CFI (Comparative Fit Index)                     | > 0,95               |
| RMSEA (Root Mean Square Error of Approximation) | < 0,08               |
| SRMR (Standardized Root Mean Residual)          | < 0,10               |
| TLI (Tucker-Lewis Index)                        | > 0,90               |

### 3.3 Fiabilidad (Consistencia interna)

Se calculará el **Alpha de Cronbach ( $\alpha$ )** por sub-escala (objetivo  $\alpha \geq 0,70$ ):

| Sub-índice | Ítems principales            | Umbral $\alpha$ mínimo |
|------------|------------------------------|------------------------|
| IGC        | P1.1, P1.3, P1.4, P1.5       | $\geq 0,70$            |
| ICM        | P3.1, P3.3, P3.4, P3.5       | $\geq 0,70$            |
| IAR        | P5.1, P5.2, P5.3, P5.4       | $\geq 0,70$            |
| IRD        | P6.1, P6.2, P6.3, P6.4       | $\geq 0,70$            |
| IBE        | P4.2, P4.4, P4.6, P4.7, P9.2 | $\geq 0,70$            |

Se calculará adicionalmente el **Omega de McDonald ( $\omega$ )** como estimador más robusto para ítems no tau-equivalentes.

### 3.4 Validez de criterio (Concurrente)

Para una submuestra con auditorías ISO 27001 o CMMC disponibles, se comparará el IGM-CAPEC calculado con las puntuaciones de madurez de dichas auditorías, esperando correlaciones positivas significativas ( $r > 0,50$ ,  $p < 0,05$ ).

## 4. DISEÑO MUESTRAL

### 4.1 Población objetivo

**Definición:** Responsables de ciberseguridad (CISO, CTO, CRO o equivalente) de organizaciones españolas con más de 50 empleados o bajo el ámbito de aplicación de NIS2 y/o ENS.

**Estimación del universo:** ~12.000 organizaciones en España bajo el ámbito de NIS2/ENS (INCIBE/CCN, 2025).

### 4.2 Tamaño muestral

Para un nivel de confianza del 95% ( $z = 1,96$ ), margen de error del 5% y varianza máxima ( $p = q = 0,5$ ):

$$n = (z^2 \times p \times q) / e^2 = (1,96^2 \times 0,5 \times 0,5) / 0,05^2 \approx 384 \rightarrow 400 \text{ cuestionarios válidos}$$

**Sobremuestra estimada** (tasa de respuesta esperada: 15–25%): **1.600–2.700 envíos necesarios.**

#### 4.3 Técnica de muestreo

**Muestreo estratificado proporcional por:**

1. Sector de actividad (13 categorías ponderadas por peso en NIS2 Anexos I y II)
2. Tamaño de organización (5 categorías)
3. Localización geográfica (representación mínima de las 6 CC.AA. más pobladas)

**Distribución objetivo por sector (n = 400):**

| Sector                 | % estimado | n objetivo |
|------------------------|------------|------------|
| Administración Pública | 25%        | 100        |
| Banca / Financiero     | 12%        | 48         |
| Energía                | 8%         | 32         |
| Salud                  | 10%        | 40         |
| Telecomunicaciones     | 6%         | 24         |
| Transporte             | 7%         | 28         |
| Tecnología / Software  | 15%        | 60         |
| Fabricación / OT       | 8%         | 32         |
| Otros sectores         | 9%         | 36         |

#### 4.4 Criterios de inclusión y exclusión

**Inclusión:**

- Organización con sede o filial principal en España
- Más de 50 empleados o sujeta a NIS2/ENS independientemente del tamaño
- Respondente con responsabilidad directa o delegada en ciberseguridad
- Cuestionario cumplimentado al menos al 80%

**Exclusión:**

- Patrón de respuesta sospechoso (todas las Likert con el mismo valor en todas las secciones)
- Respondente sin conocimiento del dominio (P1.1 = 1 con contradicciones internas manifiestas)
- Tiempo de respuesta < 8 minutos (cuestionario completado de forma mecánica)

### 5. DISTRIBUCIÓN Y RECOGIDA DE DATOS

#### 5.1 Plataforma recomendada

**Primera opción:** LimeSurvey (autoalojado en servidor institucional) — garantiza soberanía de datos y cumplimiento RGPD sin dependencia de terceros.

**Segunda opción:** Qualtrics con DPA formalizado.

**Tercera opción:** Google Forms con cuenta Google Workspace institucional y DPA con Google Ireland Ltd.

Características mínimas del formulario:

- Barra de progreso visible
- Opción de guardar y retomar más tarde
- Diseño responsivo (móvil y tableta)
- Tiempo estimado de respuesta mostrado al inicio
- Confirmación de recepción automática

## 5.2 Canales de distribución (por orden de prioridad)

1. INCIBE — Red Nacional de CSIRT y boletines a empresas (mayor alcance empresarial)
2. CCN-CNI — Canales a organismos del Sector Público y entidades ENS
3. ISMS Forum Spain — Red de CISOs y profesionales de seguridad
4. Asociaciones sectoriales — AMETIC, CECA, SEDIA, ISACA, (ISC)<sup>2</sup>, ISMS Forum
5. LinkedIn — Campaña segmentada a perfiles CISO, CTO, CRO en España
6. Redes académicas — Grupos de investigación universitarios en ciberseguridad
7. Red del consorcio investigador — Contactos directos de los investigadores

## 5.3 Protocolo de seguimiento

| Momento   | Acción                                                           |
|-----------|------------------------------------------------------------------|
| T+0       | Envío inicial con carta de presentación institucional firmada    |
| T+7 días  | Primer recordatorio (si no hay respuesta)                        |
| T+14 días | Segundo recordatorio con énfasis en contribución al bien público |
| T+21 días | Cierre del período de recogida de datos                          |

# 6. PLAN DE ANÁLISIS ESTADÍSTICO

## 6.1 Análisis descriptivo

- Variables categóricas: Tablas de frecuencia absolutas y relativas; gráficos de barras
- Variables ordinales (Likert): Mediana, moda, frecuencias acumuladas; gráfico de Likert divergente
- Variables cuantitativas derivadas (sub-índices): Media aritmética, desviación típica, mediana, percentiles 25/75, histograma de distribución

## 6.2 Cálculo del IGM-CAPEC

**Fórmula del IGM-CAPEC global (índice ponderado):**

$$\text{IGM-CAPEC} = 0,25 \times \text{IGC} + 0,20 \times \text{ICM} + 0,20 \times \text{IAR} + 0,20 \times \text{IRD} + 0,15 \times \text{IBE}$$

**Pesos justificados:**

- IGC (0,25): El conocimiento es precondition para cualquier otra dimensión
- ICM y IAR (0,20 cada uno): Operatividad e integración regulatoria son equiparables
- IRD (0,20): La resiliencia tiene impacto directo en la continuidad del negocio
- IBE (0,15): Las brechas emergentes son críticas pero aún en estadio de adopción inicial

### Escala de niveles de madurez:

| Rango       | Nivel            | Descripción operacional                          |
|-------------|------------------|--------------------------------------------------|
| 0,00 – 0,20 | 1: Inicial       | CAPEC ausente o desconocido                      |
| 0,21 – 0,40 | 2: En Desarrollo | Conocimiento básico; implementación puntual      |
| 0,41 – 0,60 | 3: Definido      | Uso sistemático en procesos clave                |
| 0,61 – 0,80 | 4: Gestionado    | Integración amplia; métricas reportadas          |
| 0,81 – 1,00 | 5: Optimizado    | CAPEC como pilar estratégico con mejora continua |

### 6.3 Análisis inferencial

- Diferencias entre grupos: ANOVA de un factor (sectores) o Kruskal-Wallis si no se cumple normalidad (test de Shapiro-Wilk previo)
- Correlaciones: Rho de Spearman entre IGM-CAPEC y variables de clasificación
- Regresión múltiple: IGM-CAPEC como variable dependiente; sector, tamaño y marcos normativos como predictoras
- Clustering: Análisis jerárquico (Ward, distancia euclidiana) para identificar perfiles típicos de adopción

### 6.4 Análisis cualitativo (P10.4 y P10.5)

- Análisis de contenido temático según Braun & Clarke (2006)
- Proceso: Codificación abierta → codificación axial → saturación temática
- Herramientas sugeridas: Atlas.ti, NVivo, o análisis manual con hojas de codificación estandarizadas
- Criterio de saturación: No emergencia de nuevos códigos en las últimas 20 respuestas procesadas

## 7. CONSIDERACIONES ÉTICAS Y RGPD

### 7.1 Base legal del tratamiento

- Base legal: Consentimiento explícito e informado (Art. 6.1.a RGPD)
- Finalidad: Investigación académica en ciberseguridad sin fines comerciales
- Datos tratados: Exclusivamente datos profesionales; sin datos personales identificativos directos
- Conservación: 5 años desde la publicación de los resultados finales

### 7.2 Medidas de anonimización

- Código alfanumérico aleatorio para cada cuestionario (sin vinculación a correo o nombre)
- Sin recogida de información identificativa personal
- Resultados solo agregados para grupos de  $n \geq 10$
- Almacenamiento en servidor bajo jurisdicción española con cifrado en reposo

### 7.3 DPIA (Data Protection Impact Assessment)

Se realizará una DPIA conforme al Art. 35 RGPD si el tratamiento implica datos sobre vulnerabilidades de organizaciones de infraestructuras críticas.

## 8. CRONOGRAMA DE INVESTIGACIÓN

| Fase | Actividad                                | Duración  | Período estimado |
|------|------------------------------------------|-----------|------------------|
| 1    | Diseño final del instrumento             | 3 semanas | Feb 2026         |
| 2    | Validación por panel de expertos (CVI)   | 3 semanas | Mar 2026         |
| 3    | Estudio piloto (n = 50)                  | 2 semanas | Mar-Abr 2026     |
| 4    | Análisis piloto y ajuste del instrumento | 1 semana  | Abr 2026         |
| 5    | Distribución masiva                      | 3 semanas | Abr-May 2026     |
| 6    | Período de recogida de datos             | 3 semanas | May 2026         |
| 7    | Limpieza y codificación                  | 2 semanas | Jun 2026         |
| 8    | Análisis estadístico                     | 4 semanas | Jun-Jul 2026     |
| 9    | Análisis cualitativo                     | 2 semanas | Jul 2026         |
| 10   | Redacción del informe                    | 4 semanas | Jul-Ago 2026     |
| 11   | Revisión y publicación                   | 3 semanas | Sep 2026         |

## 9. REFERENCIAS METODOLÓGICAS

- Babbie, E. (2016). The Practice of Social Research (14.<sup>a</sup> ed.). Cengage Learning.
- Basili, V. R., Caldiera, G., & Rombach, H. D. (1994). The Goal Question Metric Approach. Encyclopedia of Software Engineering, 2, 528–532.
- Braun, V., & Clarke, V. (2006). Using thematic analysis in psychology. Qualitative Research in Psychology, 3(2), 77–101.
- Cronbach, L. J. (1951). Coefficient alpha and the internal structure of tests. Psychometrika, 16(3), 297–334.
- Lawshe, C. H. (1975). A quantitative approach to content validity. Personnel Psychology, 28(4), 563–575.
- McDonald, R. P. (1999). Test Theory: A Unified Treatment. Lawrence Erlbaum Associates.
- MITRE Corporation. (2024). CAPEC v3.9. <https://capec.mitre.org>
- NIST. (2024). Cybersecurity Framework 2.0. <https://www.nist.gov/cyberframework>